

Аудит безопасности Wi-Fi: Полное руководство по взлому и защите

 redsec.by/article/audit-bezopasnosti-wi-fi-polnoe-rukovodstvo-po-vzlomu-i-zashite

Red Teams | 29 октября 2025



Почему аудит Wi-Fi критически важен

Беспроводные сети стали критически важной частью корпоративной и домашней инфраструктуры. Однако эта повсеместность делает Wi-Fi одним из наиболее уязвимых векторов атак. По данным исследований 2024-2025 годов, **большинство беспроводных сетей содержат уязвимости**, которые могут быть эксплуатированы при помощи доступных инструментов. Аудит безопасности беспроводных сетей —

это не просто технический процесс, а критически важная процедура, позволяющая выявить слабые места до того, как их обнаружат злоумышленники.

Данное руководство представляет собой комплексный обзор методологии тестирования безопасности Wi-Fi сетей, охватывающий практические аспекты от базовых атак на WPA2-PSK до сложных сценариев компрометации корпоративных WPA-Enterprise сетей.

Важное юридическое предупреждение: Все описанные методы должны применяться исключительно в рамках авторизованного тестирования на проникновение с письменного разрешения владельца сети. Несанкционированный доступ к беспроводным сетям является уголовным преступлением в большинстве юрисдикций, включая Беларусь, Россию, США и страны ЕС.

Часть 1: Основы и подготовка к аудиту беспроводных сетей

Понимание архитектуры 802.11

Прежде чем приступать к практическим атакам, необходимо понимать базовую архитектуру беспроводных сетей стандарта IEEE 802.11.

Типы фреймов 802.11:

- **Management frames (управляющие кадры):** Используются для управления соединением (Beacon, Authentication/Deauthentication, Probe Request/Response). **Ключевое значение для атак**, так как в WPA2 и более ранних версиях они могут передаваться незашифрованными, что позволяет проводить атаки типа деаутентификации.
- **Control frames (контрольные кадры):** Управляют доступом к среде (RTS/CTS, ACK).
- **Data frames (кадры данных):** Непосредственная передача данных (QoS Data).

Подготовка окружения для тестирования

Операционная система

Оптимальным выбором является **Kali Linux** — специализированный дистрибутив для тестирования на проникновение, содержащий все необходимые инструменты.

Беспроводной адаптер

Критически важно использовать адаптер, поддерживающий **режим мониторинга (monitor mode)** и **инъекцию пакетов (packet injection)**.

Рекомендуемые чипсеты для 2025 года:

Чипсет	Частоты	Monitor Mode	Injection	Особенности
Atheros AR9271	2.4 GHz	✓	✓	Нативная поддержка в ядре Linux, максимальная стабильность
Realtek RTL8812AU	2.4/5 GHz	✓	✓	Отличный баланс цены и производительности, dual-band
Realtek RTL8814AU	2.4/5 GHz	✓	✓	Поддержка 4 антенн, максимальная дальность
MediaTek MT7612U	2.4/5 GHz	✓	✓	Современная альтернатива с отличной поддержкой Linux
Ralink RT5572	2.4/5 GHz	✓	✓	Хорошая производительность, надежность

Топовые модели адаптеров: Alfa AWUS036ACH (RTL8812AU), Alfa AWUS1900 (RTL8814AU), Alfa AWUS036NHA (AR9271), TP-Link Archer T3U Plus.

Проверка возможностей адаптера:

```
# Проверка режима мониторинга
sudo airmon-ng start wlan0
iwconfig
```

```
# Тест инъекции пакетов
sudo aireplay-ng --test wlan0mon
```

Базовый набор инструментов

- **aircrack-ng suite:** Базовый набор для работы с Wi-Fi (airodump-ng, aireplay-ng, aircrack-ng).
- **hashcat:** GPU-ускоренный взлом хешей.
- **hcxdumpool/hcxpcapngtool:** Современные инструменты для PMKID атак.
- **Fluxion / Wifiphisher:** Автоматизация Evil Twin атак.
- **hostapd-mana / EAPHammer:** Атаки на WPA-Enterprise.
- **Bettercap:** Современный framework для MITM атак.
- **Wireshark:** Глубокий анализ сетевого трафика.

Часть 2: Атаки на WPA2-Personal (WPA2-PSK)

Теоретическая основа: 4-way handshake

WPA2-Personal использует механизм **4-way handshake** для взаимной аутентификации клиента и точки доступа. Цель злоумышленника — перехватить эти 4 сообщения, чтобы затем провести офлайн-атаку на пароль. В процессе рукопожатия генерируется ключ **PTK (Pairwise Transient Key)**, который используется для шифрования данных.

Захват WPA2 Handshake: Пошаговая инструкция

Шаг 1: Подготовка адаптера

```
# Остановка конфликтующих процессов
sudo airmon-ng check kill
# Перевод адаптера в режим мониторинга
sudo airmon-ng start wlan0
```

Шаг 2: Сканирование целевых сетей

```
# Сканирование для поиска цели (BSSID и канал)
sudo airodump-ng wlan0mon
```

Шаг 3: Фокусированный захват трафика

```
# Захват трафика целевой сети с сохранением в файл
sudo airodump-ng -c <CHANNEL> --bssid <AP_BSSID> -w capture wlan0mon
```

Шаг 4: Принудительное переподключение клиента (деаутентификация)

Чтобы заставить клиента переподключиться и инициировать новое рукопожатие, выполните в отдельном терминале:

```
# Деаутентификация конкретного клиента
sudo aireplay-ng --deauth 10 -a <AP_BSSID> -c <CLIENT_MAC> wlan0mon
```

При успешном захвате в окне airodump-ng появится сообщение: **WPA handshake: <BSSID>**.

PMKID Attack: Атака без клиентов

Открытая в 2018 году, эта атака **не требует наличия подключенных клиентов**. Она эксплуатирует функцию Fast Roaming (802.11r), позволяя извлечь PMKID (Pairwise Master Key Identifier) из первого EAPOL-фрейма.

- **Преимущества:** Не нужны клиенты, атака пассивна и очень быстра.
- **Ограничения:** Работает только если точка доступа поддерживает роуминг.

Практическая реализация с hcxdumptool:

1. Захват PMKID

```
sudo hcxdumptool -i wlan0mon -o pmkid_capture.pcapng --enable_status=1
```

2. Конвертация для hashcat

```
hcxpcapngtool -o pmkid.hc22000 pmkid_capture.pcapng
```

Взлом захваченных хешей (Handshake / PMKID)

Подготовка словарей паролей

- **RockYou.txt:** Стандартный словарь, доступный в Kali Linux.
- **Crunch:** Генератор для создания пользовательских словарей по заданным правилам (crunch 8 10 0123456789 -o numbers.txt).
- **CeWL:** Инструмент, который создает словарь из слов, найденных на веб-сайте целевой компании.

Взлом с Aircrack-ng (на CPU)

Базовая атака словарем

```
aircrack-ng -w /usr/share/wordlists/rockyou.txt capture-01.cap
```

GPU-ускоренный взлом с Hashcat

Hashcat использует мощность видеокарты для многократного ускорения перебора.

- **Конвертация файла захвата:**

```
hcxpcapngtool -o capture.hc22000 capture-01.cap
```

- **Запуск атаки:**

Атака словарем (режим -a 0)

```
hashcat -m 22000 -a 0 capture.hc22000 /path/to/wordlist.txt
```

Брутфорс по маске: 8 цифр (режим -a 3)

```
hashcat -m 22000 -a 3 capture.hc22000 ?d?d?d?d?d?d?d?d
```

- -m 22000: Режим для WPA-PSK.
- ?d: Маска для цифр, ?l для строчных букв, ?u для заглавных.

Производительность GPU: Современные GPU, такие как **NVIDIA RTX 4090**, могут проверять **около 900-950 тысяч паролей в секунду**, делая короткие и простые пароли крайне уязвимыми.

Часть 3: Evil Twin атаки и Captive Portal

Evil Twin — это атака типа "человек посередине", при которой создается поддельная точка доступа, имитирующая легитимную сеть, для перехвата паролей или трафика.

Принцип работы Evil Twin

- **Создание поддельной AP:** Запускается точка доступа с тем же SSID, что и у цели.
- **Деаутентификация клиентов:** Пользователи отключаются от легитимной сети.
- **Подключение жертв:** Устройства автоматически подключаются к поддельной AP с более сильным сигналом.
- **Фишинг через Captive Portal:** Пользователя перенаправляют на фишинговую страницу, требующую ввести пароль от Wi-Fi для "восстановления доступа".

Автоматизация атак с Fluxion и Wifiphisher

Вместо ручной настройки, можно использовать готовые фреймворки.

- **Fluxion:** Мощный скрипт, который автоматизирует весь процесс: сканирование, захват handshake, создание поддельной AP и фишингового портала.
- **Wifiphisher:** Фреймворк с множеством готовых сценариев фишинга (например, "обновление прошивки роутера", "окно сетевого менеджера Windows", "OAuth-авторизация").

Запуск Wifiphisher:

```
# Базовая автоматическая атака  
sudo wifiphisher
```

```
# Атака на конкретную сеть с определенным сценарием  
sudo wifiphisher -i wlan0 -e "TargetNetwork" -p firmware-upgrade
```

Часть 4: Атаки на корпоративные сети WPA-Enterprise

WPA-Enterprise использует RADIUS-сервер для централизованной аутентификации, что делает его значительно более защищенным. Однако и здесь есть векторы атак.

Архитектура WPA-Enterprise и методы EAP

- **Компоненты:** Supplicant (клиент), Authenticator (точка доступа), Authentication Server (RADIUS).
- **Методы EAP:**
 - **EAP-TLS:** Самый безопасный, использует сертификаты клиента и сервера.
 - **PEAP-MSCHAPv2:** Самый распространенный, использует логин и пароль в защищенном TLS-туннеле. **Именно он часто является целью атак.**

Evil Twin атака на PEAP-MSCHAPv2

Уязвимость: Большинство клиентов по умолчанию **не проверяют валидность сертификата** поддельного RADIUS-сервера.

Инструменты: hostapd-mana и EAPHammer.

Процесс атаки:

- Злоумышленник создает поддельную корпоративную сеть (Evil Twin).
- Для аутентификации используется hostapd-mana, настроенный как поддельный RADIUS-сервер с самоподписанным сертификатом.
- Клиенты подключаются и передают свои учетные данные (challenge/response) на сервер злоумышленника.

Взлом MSCHAPv2 хешей

Захваченный challenge-response MSCHAPv2 можно взломать офлайн.

- **Инструмент:** Hashcat в режиме **-m 5500 (NetNTLMv1)**.
- **Сервисы:** Онлайн-сервис crack.sh специализируется на взломе MSCHAPv2.

Важно: После взлома получается NT-хеш пароля, который можно использовать напрямую для аутентификации без знания самого пароля (Pass-the-Hash).

Часть 5: Атаки на уязвимый протокол WPS

Wi-Fi Protected Setup (WPS) был создан для упрощения подключения, но содержит критические уязвимости, делающие его легкой мишенью.

WPS PIN Brute-Force

Уязвимость: 8-значный PIN разбит на две половины, которые проверяются отдельно. Это снижает количество комбинаций со 100 миллионов до всего **~11,000**, что позволяет осуществить полный перебор за несколько часов.

Инструменты: Reaver, Bully.

Пример атаки с Reaver:

```
# 1. Сканирование WPS-enabled сетей
wash -i wlan0mon
```

```
# 2. Атака на целевую AP
reaver -i wlan0mon -b <BSSID> -c <CHANNEL> -vv
```

Pixie Dust атака

Уязвимость: Некоторые производители роутеров (Ralink, MediaTek, Realtek) использовали слабую генерацию случайных чисел (nonce) в протоколе WPS. Атака **Pixie Dust** позволяет восстановить PIN-код офлайн за считанные секунды.

Пример атаки с Reaver:

```
reaver -i wlan0mon -b <BSSID> -c <CHANNEL> -K 1 -N -vv
```

Защита: Единственная эффективная мера — **полное отключение WPS** в настройках роутера.

Часть 6: Методы защиты и обнаружения атак

Рекомендации по защите WPA2/WPA3-Personal

- **Использовать WPA3:** Где это возможно, используйте режим **WPA3-only**. Он защищен от офлайн-атак и использует современный протокол SAE.
- **Сильные пароли:** Используйте парольные фразы длиной **минимум 16-20 символов**.
- **Включить PMF/802.11w: Protected Management Frames** защищают от атак деаутентификации. В WPA3 эта функция включена по умолчанию.
- **Отключить WPS:** Полностью деактивируйте эту уязвимую функцию.
- **Регулярно обновлять прошивку** роутера.

Рекомендации по защите WPA-Enterprise

- **Использовать EAP-TLS:** Аутентификация на основе сертификатов клиентов является самым безопасным методом.
- **Принудительная проверка сертификатов:** Настройте клиентские устройства так, чтобы они доверяли только сертификатам, выданным вашим доверенным центром сертификации (CA).
- **Сильная парольная политика** и использование **MFA** для RADIUS-аутентификации.

Обнаружение атак: WIDS/WIPS

Wireless Intrusion Detection/Prevention System — это специализированные системы для мониторинга и защиты беспроводных сетей.

Что обнаруживает WIDS:

- **Rogue Access Points** (несанкционированные точки доступа).
- **Evil Twin** атаки (клонированные SSID).

- **Деаутентификационные атаки** (аномальный трафик).
- Попытки **WPS brute-force**.

Решения:

- **Коммерческие:** Aruba ClearPass, Cisco ISE, Fortinet FortiWLM.
- **Open-source:** Kismet, Snort, Suricata.

Часть 7: Продвинутые техники

Использование Bettercap для MITM

Bettercap — это мощный швейцарский нож для пентестера, позволяющий проводить комплексные атаки.

Возможности Wi-Fi атак:

Запуск в интерактивном режиме

```
sudo bettercap -iface wlan0
```

Внутри bettercap:

```
> wifi.recon on           # Включить разведку
> wifi.deauth <BSSID>    # Деаутентифицировать всех клиентов
> set wifi.ap.ssid "EvilAP" # Настроить Evil Twin
> wifi.ap on             # Запустить Evil Twin
```

После подключения клиентов к Evil Twin, Bettercap можно использовать для **ARP/DNS spoofing**, перехвата и модификации **HTTP/HTTPS трафика**.

Атаки на WPA3 (Dragonblood)

WPA3 значительно улучшает безопасность, но ранние реализации были подвержены **Dragonblood** атакам:

- **Downgrade атака:** Принуждение устройств в режиме WPA3-Transition к использованию уязвимого WPA2.
- **Side-channel атаки:** Timing-based и cache-based атаки на рукопожатие Dragonfly.
- **DoS атаки:** Перегрузка CPU точки доступа путем флуда SAE-фреймами.

Защита: Использовать режим WPA3-only и своевременно обновлять прошивки.

Анализ трафика с Wireshark

Wireshark — незаменимый инструмент для глубокого анализа. При наличии пароля от сети (PSK) он может **расшифровывать WPA2 трафик**.

Полезные фильтры:

- **eaarpol:** Отображение только пакетов рукопожатия (handshake).
- **wlan.fc.type_subtype == 0x0c:** Поиск кадров деаутентификации.
- **wlan.fc.type_subtype == 0x04:** Probe requests, которые могут раскрыть историю сетей, к которым подключался клиент.

Часть 8: Юридические аспекты и этика пентеста

Законодательство

Несанкционированный доступ к компьютерным системам является федеральным преступлением в большинстве стран.

- **США:** Computer Fraud and Abuse Act (CFAA).
- **Россия:** Статьи 272, 273, 274 УК РФ.
- **Беларусь:** Статьи 349, 350 УК РБ.

Требования к авторизованному тестированию

Для легального проведения тестирования на проникновение обязательны следующие документы:

- **Письменное разрешение** от владельца сети.
- **Детальное определение scope** (область тестирования): SSID, локации, временные рамки.
- **Rules of Engagement** (правила взаимодействия).
- **NDA (Non-Disclosure Agreement)** - Соглашение о неразглашении.

Профессиональные сертификации

- **OSWP (Offensive Security Wireless Professional):** Практическая сертификация, фокусирующаяся на наступательных техниках.
- **CWSP (Certified Wireless Security Professional):** Фокус на проектировании и защите беспроводных сетей.
- **CEH (Certified Ethical Hacker)** и **GPEN (GIAC Penetration Tester)** также включают модули по тестированию беспроводных сетей.

Ключевые выводы и тренды

Аудит безопасности беспроводных сетей является критически важной процедурой. Даже сети, защищенные WPA2 и WPA3, могут быть уязвимы из-за слабых паролей, социальной инженерии, уязвимостей в реализации протоколов и недостаточной проверки сертификатов.

Ключевые выводы для организаций:

- Регулярно проводите авторизованные пентесты беспроводной инфраструктуры.
- Мигрируйте на **WPA3** и включайте **PMF (802.11w)**.
- **Отключите WPS** на всех устройствах.
- Внедряйте **WIDS/WIPS** для раннего обнаружения атак.
- Проводите обучение пользователей для распознавания Evil Twin атак.

Ключевые выводы для специалистов по безопасности:

- Строго соблюдайте этические нормы и законодательство.
- Следуйте признанным методологиям (PTES, OWASP).
- Получайте профессиональные сертификации (OSWP, CWSP) для подтверждения квалификации.
- Постоянно обновляйте знания о новых атаках, инструментах и методах защиты.

Помните: Информация в этом руководстве предназначена исключительно для образовательных целей и авторизованного тестирования на проникновение. Несанкционированный доступ к беспроводным сетям является серьезным преступлением.

Дополнительные ресурсы для изучения

- **Документация:** IEEE 802.11 Standards, Wi-Fi Alliance WPA3 Specification, NIST Cybersecurity Framework.
- **Обучающие платформы:** Offensive Security (OSWP course), HackTheBox Academy, PentesterAcademy.
- **Книги:** "Penetration Testing: A Hands-On Introduction to Hacking" (Georgia Weidman), "The Hacker Playbook 3" (Peter Kim).
- **Инструменты (GitHub):** aircrack-ng, hashcat, FluxionNetwork, wifiphisher.